UNIVERSITY OF LONDON
BSc ALTERNATIVE ASSESSMENT 2021

For Internal Students of

Royal Holloway

IY3612: Cyber Security

IY3612R: Cyber Security (PAPER FOR FIRST SITS/RESIT CANDIDATES)

Time Allowed: **TWO hours**

Attempt **three** questions

No credit will be given for attempting any further questions

- Answers must be hand-written with module and candidate numbers at the top of each page. Photograph or scan all pages, and retain paper originals for reference by examiners.
- For each attempted question, clearly state the question number.
- Do not include Student ID Number or name, only candidate number
- **Academic Misconduct:** All assessments will be checked for academic misconduct. Any suspected offences will be dealt with under the College's Academic Misconduct procedures.
  - The work submitted is expected to be your own work and only your work. You may not ask for help with the assessments from any source, or copy anyone else's work.
  - You must not give help to anyone else, including sending them any parts of the questions or copies of your solutions
  - You must not discuss the questions or solutions with anyone else
- **Submitting your work**:
  - Your document must be submitted through Moodle as a single PDF file
  - Emailed submissions will not be accepted
  - The exam must be uploaded within one hour of finishing the exam

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

© Royal Holloway University of London 2021

Question 1 Targeted Attacks

A well-resourced adversary wishes to both discredit the product quality of a vaccine manufacturer and to steal trade secrets from the R&D system at the same time.

(a) Assume that the relevant R&D data is held on a separate network not connected to the Internet. How can the adversary learn about the location of the data and successfully exfiltrate these if only a remote cyber attack is possible?

Give a description of possible steps taken by the adversary beginning with intelligence gathering; do *not* merely reproduce a generic framework, but address how such an air-gapped system can still be compromised [17]

(b) To discredit the product quality, the attacker identified in question 1(a) seeks to disrupt production processes in such a way that quality control processes *will* detect anomalies.

The attacker could not penetrate into the production system, but has successfully compromised systems on the business network also used to prepare shipments of the vaccine to an independent testing laboratory.

Can a manipulation of systems and databases call the product quality into question? Briefly identify a scenario and elaborate how the adversary would achieve a violation of quality requirements. [8]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2 Modelling Attacks

(a) When studying the robustness of networks, *betweenness centrality* is a frequently-used measure identifying the fraction of shortest paths between arbitrary vertices s, t in a given graph.

Given a graph $G = (V, E)$ with V the vertex set and $E \subset \binom{V}{2}$ the edge set, the number of shortest paths between s and t defined by σ_{st} and with $\sigma_{st}(x)$ the number of shortest paths passing through x, the betweenness centrality of $x \in V$ is defined as

$$BC(x) = \sum_{s \neq x \neq t} \frac{\sigma_{st}(x)}{\sigma_{st}}.$$

The most efficient *exact* algorithm to determine betweenness centrality for a given vertex has a time complexity of $O(|V||E|)$.

(i) When countering an on-going attack rendering nodes in a network inoperable, can it be preferable to use an *approximate* algorithm for determining betweenness centrality if this allows faster computation?

Give a reasoned explanation why this may or may not be desirable, and which drawbacks need to be considered depending on the size on the network to be protected. [12]

(ii) A less computationally demanding ($O(|E|)$) metric to determine the attractiveness of nodes for an adversary is based on simply measuring the *degree* of vertices. This is known to be largely equivalent in effectiveness to the betweenness centrality measure in case of scale-free graphs such as the Internet's AS structure.

Would this metric be appropriate for an attacker if the target network consisted of a connected core subgraph with branches where each vertex has only two neighbours? [13]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3 Network Robustness

(a) The global structure of the Internet is approximated by a scale-free graph at the level of BGP interconnectivity.

(i) Consider two arbitrary nodes on the Internet wishing to communicate. If one were to follow the scale-free graph model directly, how would packets between these nodes be routed? [8]

(ii) Give a detailed description and explanation for how real routing in the Internet will differ from the simplified model discussed under question 3(a)(i), and why this is the case. [7]

(b) Global Internet traffic also heavily depends on the use of subsea cables. Give an explanation on whether and how these physical infrastructure elements should be incorporated into logical connectivity models discussed in question 3(a), particularly when studying potential vulnerabilities. [10]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4 Attacks on Cyber-Physical Systems

Consider an attack in which an attacker has successfully implanted malware in an actuator IED. The attacker has deployed code which will execute all commands sent to the actuator, but will delay execution of some commands (randomly) by a random amount even though a success return message is sent to the originating PLC.

(a) If the target system is operating a closed-loop control system: Which kinds of damage can such an attacker achieve, and under which circumstances? Give a reasoned explanation. [15]

(b) Assuming that the compromised IED is connected to a field bus together with other sensors and actuators in the system (i.e. can read and write messages on the same bus): How could the attacker improve the damage done by the attack described in question 4(a) by observing data on the field bus, even without having remote control or compromising other nodes? [10]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5 Attack Modelling

(a) **Game-theoretical models** can be instructive for both attackers and defenders to help understand which course of action, or strategy, to choose. In the simplest models, only two parties (one attacker, one defender) are considered.

(i) Give an informal definition and explanation of a **strategy set**. [5]

(ii) How are pure strategies distinguished from mixed strategies in game-theoretic models? [5]

(b) Modelling attacks consisting of multiple strands or where several stages must be completed in sequence for an attack to succeed allows the identification of suitable countermeasures and mitigation strategies. **Attack trees** are a straightforward mechanism for capturing such attacks.

(i) Give a brief definition of an attack tree, including the construction of the tree for an attack in which two redundant network components must be compromised simultaneously by the attacker in order to be successful. [10]

(ii) Assuming a graphical representation of an attack tree, describe how the tree can be transformed into its algebraic equivalent. [5]

END

Stephen Wolthusen

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.